ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

SEL acSELerator RTAC (SEL-5033) - SEL RTAC configuration software · Component type: **Software Application (SAR) - RTAC engineering/configuration software** · Target SL = SL 3

Where to work	**acSELerator RTAC (SEL-5033)** on a Windows host (Win 10 / 11 / Server 2019). A **project** holds the complete configuration, settings, and IEC 61131 logic for one RTAC. Security is authored in the project **plus** the RTAC **web interface**: user accounts + **LDAP/RADIUS**; **Security › CA Certificates / SSH Keys**; the stateful firewall via **Network › Interface**; **Network › Syslog**; logging via **Tag Processor › Options › Logging Layout**. The **Advanced Settings** toggle (top-right in acSELerator RTAC) exposes settings such as *Verify SSL Certificate*. Software + device definitions delivered signed via **SEL Compass**. Assess the RTAC itself on the SEL-3350 / SEL-3505 sheets.
Ports / paths	acSELerator RTAC connects to the RTAC over **TLS**: **5432** (project download & retrieval / ODBC), **443 HTTPS** (RTAC web server - accounts, certs, firewall, syslog config), **80 HTTP** (migrated/redirected to 443), **123 NTP**; control protocols e.g. DNP3 **20000**; engineering access via the **SEL server** (SSH tunnel) or **SSL/TLS serial tunneling**. The project + custom templates + certs/keys live on the host - protect them.
Notes	SAR - SEL acSELerator RTAC SEL-5033 (SEL RTAC configuration software). Its distinctive control is that the RTAC hardening is configured from this tool + the paired web interface, so verify the engineer USES it to enforce the controls. Confirm the acSELerator RTAC version + patch level (SEL Compass) and subscribe to **SEL Security Notifications**. exe-GUARD whitelisting runs on the RTAC (R134+, not user-disablable).
How to read	Each row = native step-by-step (acSELerator RTAC / RTAC web interface / host) + command-level external-tool steps. Default read-only. Mark Pass/Fail/Partial/N/A. Write/exploit tools = isolated env + written authorization.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Confirm access is layered: (1) the host **Windows account** controls who may run acSELerator RTAC; (2) going online / downloading a project to the RTAC requires an RTAC **user account** (unique username + password + role) over TLS - no anonymous configuration. Accounts are managed in the RTAC **web interface** (each has a username, password, and role) or via **LDAP/RADIUS**. **Test:** from acSELerator RTAC, attempt to go online / download to the RTAC without valid credentials -> refused; browse the web interface without login -> refused. **Ext. tools:** acSELerator RTAC (Go Online / account prompt); RTAC web `https://` (login required); `nmap -p 5432,443 .`	Software run + RTAC config both authenticate; unique accounts/roles; no anonymous access.	
SR/CR 1.2	Software process / device identification	Confirm each RTAC is uniquely identified (IP / hostname) and acSELerator RTAC addresses only the intended device; the project download over TLS (5432) binds the target; connected IEDs carry unique names/IDs in the project tree. **Ext. tools:** acSELerator RTAC (device/IED tree, target IP); `openssl s_client -connect :443`; Wireshark `tls`.	Unique, TLS-bound device identity; no rogue targets.	
SR/CR 1.3	Account management	Manage: (a) host/AD accounts allowed to run acSELerator RTAC (least privilege); (b) RTAC user accounts + roles authored via the web interface / project; (c) central **LDAP/RADIUS** where used. Remove default/shared accounts; enable **Inactive Account Logouts**. **Ext. tools:** acSELerator RTAC / RTAC web (Users & Roles, LDAP/RADIUS); host/AD account review.	Host + RTAC + central accounts managed/least-privilege; defaults removed.	
SR/CR 1.4	Identifier management	Confirm unique host user IDs, a unique RTAC device identity (hostname/IP), and unique RTAC account names; no reuse across users or devices. **Ext. tools:** Host/AD; RTAC web (account list); acSELerator RTAC (device identity).	Unique user and device identifiers; no reuse.	
SR/CR 1.5 / 1.7	Authenticator management & strength	Confirm the RTAC **Strong Passwords** policy (length/complexity) or the upstream LDAP/RADIUS policy; host/AD password policy for the acSELerator RTAC login; rotate/expire; no defaults. **Ext. tools:** RTAC web (password policy); LDAP/RADIUS policy; host/AD policy; attempt weak password -> rejected.	Strong password policy enforced (RTAC or central); defaults changed; managed lifecycle.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.6	Wireless access management	**N/A.** Configuration software with no wireless interface. **Ext. tools:** Confirm no software wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A
SR/CR 1.8 / 1.9	PKI certificates & key strength	The RTAC web server ships a **default self-signed X.509** certificate (browser warning). Generate an X.509 + CSR, have your org **CA** sign it, then import + activate it on the RTAC; for two-way TLS install the client CA chain under **Security › CA Certificates**. Require TLS 1.2+ (RTAC supports TLS 1.0+; disable weak) and strong keys (>=2048 RSA / ECC). **Ext. tools:** RTAC web (Security › CA Certificates; cert activate); `openssl x509 -noout -issuer -dates`; `sslscan :443`.	CA-signed cert installed + activated; default self-signed replaced; strong keys; TLS 1.2+.	
SR/CR 1.10	Authenticator feedback	Confirm acSELerator RTAC and the RTAC web login mask password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm the RTAC / central directory responds to repeated failed logons (lockout + **Inactive Account Logouts**); host/AD lockout for the acSELerator RTAC login; failures logged to the SOE / SIEM. **Ext. tools:** RTAC web (login policy); repeated invalid logins (authorized); SOE / SIEM failed-auth review.	Lockout / logout on excess failures; failures logged.	
SR/CR 1.12	System use notification	No dedicated acSELerator RTAC banner; enforce the approved use notice on the engineering-workstation host (GPO) and on the RTAC web login where supported. **Ext. tools:** Host `gpresult /h gp.html`; RTAC web login (banner check).	Use notice presented before access (host, compensating).	Compensating.
SR/CR 1.13	Access via untrusted networks	Confirm the acSELerator RTAC host + RTAC sit in the trusted substation/OT zone; remote engineering via VPN / jump host; **disable Web + ODBC access on untrusted interfaces** (RTAC web: Network › Interface, uncheck *Enable Web Access* / *Enable ODBC Access*) so 443/5432 are firewalled off-segment. **Ext. tools:** `nmap -Pn -p 5432,443,80` from the untrusted side (expect filtered); RTAC web (Network › Interface); firewall review.	Engineering/config access from untrusted networks denied; remote via VPN; unused interfaces disabled.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Authorization is enforced by RTAC **roles** - confirm a read-only/limited user cannot download settings, change logic, or operate control. The **SEL server** sets *Perform Authentication*=True automatically when SSH is the tunnel mode. **Test:** as a read-only RTAC user, attempt a project download / config change -> denied. **Ext. tools:** acSELerator RTAC / RTAC web (role review); read-only negative test (isolated).	Least privilege enforced by role; privileged actions denied.	
SR/CR 2.2	Wireless use control	**N/A.** Software, no wireless interface. **Ext. tools:** Confirm no wireless.	N/A - justification recorded.	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the acSELerator RTAC laptop and removable media (OS device-control); only authorized projects / firmware / library extensions are loaded; the RTAC local **USB-B** service interface is controlled. **Ext. tools:** Host removable-media GPO; confirm authorized project source; physical USB-B control (per RTAC sheet).	Portable/engineering media controlled; only authorized artifacts loaded.	
SR/CR 2.4 (+ SAR 2.4)	Mobile code	No general-purpose mobile code; confirm only the signed acSELerator RTAC runs and only reviewed IEC 61131 logic / SEL **library extensions** are used; on the RTAC, **exe-GUARD** whitelisting (R134+, not user-disablable) blocks any unauthorized executable. **Ext. tools:** acSELerator RTAC (library-extension / logic review); RTAC exe-GUARD tags (`SystemTags.Whitelist_Alert`).	Only signed software + reviewed logic/libraries; exe-GUARD blocks unauthorized code.	SAR-specific.
SR/CR 2.5	Session lock	Confirm the host OS screen lock on inactivity; acSELerator RTAC / RTAC web re-authenticate after lock; **Inactive Account Logouts** close idle RTAC sessions. **Ext. tools:** Host inactivity-lock GPO; RTAC web (inactive-logout setting).	Host locks on inactivity; RTAC logs out idle sessions; re-auth required.	Compensating (host).

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.6 / 2.7	Remote session termination & concurrency	Confirm acSELerator RTAC / web sessions can be ended, idle sessions close (Inactive Account Logouts), and simultaneous conflicting configuration is prevented (bounded concurrent connections). **Ext. tools:** RTAC web (active sessions / logout); Wireshark (session teardown).	Sessions terminable; idle sessions close; concurrency bounded.	
SR/CR 2.8 / 2.12	Auditable events & non-repudiation	Confirm engineering/security actions are attributable and offloaded: the RTAC **SOE log** records logons and changes with user attribution (e.g. `SystemTags.User_Logged_On`), configured via **Tag Processor › Options › Logging Layout**, and is forwarded by **Syslog** (RTAC web: Network › Syslog) to the SIEM. **Test:** log on / download a change -> an SOE + Syslog event with the user + time. **Ext. tools:** acSELerator RTAC (Tag Processor Logging Layout); RTAC web (SOE); Syslog listener (`nc -lu 514`) + SIEM.	Logons/changes attributable in the SOE; forwarded to the SIEM.	
SR/CR 2.9 / 2.10	Audit storage capacity & failure handling	The RTAC **SOE log stores up to 30,000 items** - confirm Syslog / ODBC offload to the SIEM for retention with alerting on collection failure; set the Syslog **threshold** (Logging Priority) appropriately. **Ext. tools:** RTAC web (Network › Syslog threshold); SIEM retention + source-silent alert.	Events offloaded/retained (finite local store); audit-failure alerting defined.	
SR/CR 2.11	Timestamps	Confirm the host + RTAC are time-synced (NTP / SNTP / PTP / IRIG-B at the RTAC) so SOE / audit timestamps correlate. **Ext. tools:** `w32tm /query /status` (host); acSELerator RTAC / RTAC web (time source).	Accurate, synchronized timestamps.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1 / 4.1	Communication integrity & confidentiality	acSELerator RTAC-to-RTAC comms are **TLS** (project download/retrieval 5432; web 443 HTTPS); SCADA serial protocols are tunneled via **SSL/TLS** (*Serial Tunneling Mode* in acSELerator RTAC) or SSH. Disable plain **HTTP 80**. No cleartext engineering traffic. **Ext. tools:** Wireshark `tls` (encrypted 5432/443; no cleartext config); `nmap -p 80,443,5432 .`	Config/web on TLS; SCADA tunneled TLS/SSH; HTTP disabled; no cleartext.	
SAR 3.2	Protection from malicious code (component)	Confirm software integrity: install only the SEL-**signed** acSELerator RTAC delivered via **SEL Compass** (verify the installer signature); host anti-malware; restrict install/upgrade to admins; patch per **SEL Security Notifications**. On the RTAC, exe-GUARD enforces application whitelisting. **Ext. tools:** `signtool verify /pa .exe`; host AV; SEL Compass (version/updates).	Signed software validated; install restricted; AV active; patched.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: RTAC accounts / LDAP-RADIUS, activated CA-signed cert, Network › Interface (Web/ODBC exposure), Syslog, and engineering-access auth, against the hardening baseline; export/compare the acSELerator RTAC project. **Ext. tools:** acSELerator RTAC (project compare); RTAC web (settings review); `nmap -p 5432,443 .`	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Protect the acSELerator RTAC **project** (config, IEC 61131 logic, and any embedded credentials/certs): host ACLs, encrypt at rest (BitLocker), version + change-track; use project compare to detect drift. **Ext. tools:** Host ACL on the project; acSELerator RTAC project compare; `certutil -hashfile SHA256`.	Project protected + change-tracked; integrity baselined.	
SR/CR 3.5	Input validation	Patch known acSELerator RTAC / RTAC-firmware CVEs (SEL Security Notifications / CISA) and confirm acSELerator RTAC handles malformed device responses without crashing. **ISOLATED:** test against a bench RTAC. **Ext. tools:** Nessus/OpenVAS on the host; SEL Security Notifications / CISA cross-check; ISOLATED malformed-response test.	Known CVEs patched; malformed input handled safely.	
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm errors are handled gracefully without leaking sensitive info (no plaintext passwords/keys in acSELerator RTAC logs / crash dumps). **Ext. tools:** acSELerator RTAC / host event-log review.	Graceful error handling; no secret leak.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.8	Session integrity	acSELerator RTAC-to-RTAC TLS sessions are integrity-protected against replay/hijack; confirm no unauthenticated engineering path remains (HTTP 80 disabled; SEL server *Allow Anonymous SEL IP Clients* disabled / IP-restricted). **Ext. tools:** Wireshark (TLS session); acSELerator RTAC (SEL server anonymous/IP settings).	Sessions integrity-protected; no unauthenticated/anonymous path.	
SR/CR 3.9	Protection of audit information	Protect the SOE / Syslog transport + SIEM store; restrict RTAC roles + host ACLs so logs cannot be cleared/altered by unauthorized users. **Ext. tools:** RTAC web (role review); SIEM access review; host ACL.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.2	Information persistence	On decommission/repurpose of the host, remove the acSELerator RTAC project, custom templates, certificates + private keys, and backups; confirm no plaintext secrets persist; encrypt the host disk. **Ext. tools:** Remove project/templates/certs (certmgr); confirm backups removed; BitLocker status.	Project, templates, certificates, and keys purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto: RTAC web / project-download TLS with strong suites, CA-signed cert (default self-signed replaced), strong keys; the project protected at rest (host encryption). **Ext. tools:** `sslscan :443` (or testssl.sh); confirm host disk encryption.	Modern TLS + managed certs; project encrypted at rest.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1 / 5.2	Network segmentation & zone boundary	Confirm the acSELerator RTAC host + RTAC sit in a segmented substation/OT zone behind a firewall; only required flows (5432/443) cross; remote engineering via a jump host; disable Web/ODBC on interfaces facing untrusted networks (Network › Interface). **Ext. tools:** `nmap -p 5432,443,80,123` per zone; RTAC web (Network › Interface); firewall rule review.	Host + RTAC in a segmented zone; only required flows cross.	
SR/CR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Configuration software with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR/CR 5.4	Application partitioning	Partition by criticality: separate acSELerator RTAC projects / CA scopes per substation/zone and least-privilege host access; do not co-mingle unrelated criticality. **Ext. tools:** acSELerator RTAC project/CA segregation; host access review.	Projects/CA scopes partitioned by criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1 / 6.2	Audit log accessibility & continuous monitoring	Confirm the RTAC **SOE log** is readable/exportable by authorized staff (web / ODBC) and forwarded (Syslog) to the SIEM; passive OT IDS on the substation LAN. **Ext. tools:** RTAC web (SOE export) / ODBC; Syslog + SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1 / 7.2	DoS protection & resource management	The engineering tool is not a runtime service; confirm the host is resourced/hardened and RTAC connections are bounded so a flood cannot deny engineering access; do not co-host unrelated apps. The RTAC self-configuring stateful firewall limits its own exposure. **Ext. tools:** Host resource monitor; RTAC web (Reports › Diagnostics firewall state).	Host/connection resources bounded; engineering access available.	
SR/CR 7.3 / 7.4	Backup & recovery	Confirm the acSELerator RTAC project, custom templates, and certificates/keys are backed up (versioned, offline) and a restore/rebuild is tested on a lab RTAC. **Ext. tools:** Backup repository; `certutil -hashfile SHA256`; restore + validate on a lab RTAC.	Backups current and recovery validated.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6 / 7.7	Network & security settings + least functionality	Harden: replace the default self-signed cert with a CA-signed cert, **disable unused interfaces/services** (Web/ODBC per interface, HTTP 80, NTP if unused - Network › Interface + project System_Time_Control), run acSELerator RTAC on a hardened least-privilege host, install only what is needed, keep patched (SEL notifications), and remove sample projects. **Ext. tools:** RTAC web (Network › Interface / services); acSELerator RTAC (project); host hardening review; version vs patched.	Least functionality; CA-signed cert; unused services off; patched.	
SR/CR 7.8	Component inventory	Inventory the acSELerator RTAC version (SEL Compass), installed **library extensions**, and the OS so vulnerabilities track against SEL Security Notifications / CISA. **Ext. tools:** acSELerator RTAC (About / library extensions); SEL Compass; SEL Security Notifications feed.	Accurate version/component inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
acSELerator RTAC (SEL-5033)	Native project / RBAC / cert / firewall / syslog review (all FRs)	Open an authorized project copy; review RTAC accounts + LDAP/RADIUS, Security › CA Certificates / SSH Keys, Network › Interface / Syslog, Tag Processor › Options › Logging Layout; use the Advanced Settings toggle. Assess the RTAC on its sheet. Back up the project + certs.	Read/authorized project copy; TLS.
SEL Compass	Signed software / device-definition delivery & version (SAR 3.2, 7.8)	Confirm acSELerator RTAC + device definitions are delivered/updated via Compass; verify the installer digital signature; record the version.	Read-only.
signtool	Signed-installer validation (SAR 3.2)	`signtool verify /pa .exe` or Properties › Digital Signatures; install only SEL-signed software.	Read-only.
openssl	Cert & TLS inspection (1.8, 3.1, 4.3)	`openssl s_client -connect :443 | openssl x509 -noout -issuer -dates`; confirm CA-signed, strong, valid; default self-signed replaced.	Read-only.
sslscan / testssl.sh	TLS/cipher strength (1.8, 4.3)	`sslscan :443`; confirm TLS 1.2+ and strong ciphers; flag TLS 1.0/1.1.	Read-only/safe.
nmap	Service exposure & segmentation (1.13, 3.1, 5.x)	`nmap -sT -p 5432,443,80,123,20000 -T2` ; scan per zone; confirm 80 disabled, Web/ODBC off off-segment, only required reachable.	Read-only; authorized; tune timing on production.
Wireshark / tcpdump	Comms integrity & session (3.1, 3.8)	SPAN/tap; filter `tls`; confirm TLS on 5432/443 and tunneled SCADA; no cleartext config/creds.	Passive; SPAN/tap only.
Syslog listener (nc / rsyslog)	Log offload verification (2.8, 6.x)	`nc -lu 514`; trigger a login/config event; confirm the RTAC forwards it (Network › Syslog) to the SIEM.	Coordinate with SIEM team.
Nessus / OpenVAS + SEL Security Notifications	CVE scan (3.5, 7.8)	Scan the engineering host for known acSELerator RTAC CVEs; cross-check SEL Security Notifications / CISA advisories.	ISOLATED/representative; authorization.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.